

B3-TP2 : PIPES ET REDIRECTIONS

Prérequis :	Matériels et documentation :	Durée :
B3-Cours1 : Systèmes d'exploitation	- LMDE6 - John the Ripper	2H00

Problématiques	Comment sont stockés les mots de passe des sessions Linux ? Comment tester la sécurité des mots de passe ?
Objectifs	À la fin de la séance, vous devrez être capable de : - Expliquer le principe de hachage d'un mot de passe - Effectuer des recherches sur les fichiers avec la commande <code>grep</code> - Utiliser les tubes anonymes (<i>pipes</i>) et les tubes nommées (redirections) sur des commandes

Vous allez dans ce travail pratique aborder les tubes (*pipes* et redirections) dans les commandes Linux pour extraire des informations dans des fichiers systèmes. Vous tenterez ensuite de rechercher le mot de passe de session d'un utilisateur.

1 ACTIVITÉ 1 : RECHERCHE DANS UN FICHIER AVEC LA COMMANDE GREP

- (01) Afficher dans un terminal le contenu du fichier `passwd` se trouvant dans le répertoire `/etc/`. Que représentent les lignes du fichier ? Que contiennent les 2 premiers et les 2 derniers champs ?
- (02) Afficher dans un terminal le contenu du fichier `shadow` se trouvant dans le répertoire `/etc/`. Que représentent les lignes du fichier ? Que contiennent les 2 premiers champs ?
- (03) Taper ensuite la commande `grep etudiant /etc/passwd` et l'expliquer en détail.
- (04) Effectuer une recherche avec la commande `grep` dans les fichiers `passwd` puis `shadow` avec votre login.
- (05) Comment sont stockés les mots de passe de session dans le fichier `shadow`.

2 ACTIVITÉ 2 : HACHAGE DU MOT DE PASSE

- (06) Lire la fiche sur le hachage des données présent Moodle : [F1-Fiche1 : Hachage des données](#).

Par défaut, l'algorithme ou la fonction de hachage du mot de passe utilisé par votre distribution est stocké dans le fichier `login.defs` situé dans le répertoire `/etc/`.

- (07) Donner la ligne de commande permettant de rechercher dans le fichier `login.defs` la ligne commençant par le terme `ENCRYPT_METHOD`. Conclure sur la fonction de hachage.

Généralement, si le module complémentaire appelé `pam` est activé alors il impose un nouvel algorithme de hachage au mot de passe du système.

- (08) Donner la ligne de commande permettant de rechercher dans le fichier `/etc/pam.d/common-password` la ligne contenant le terme `pam_unix.so`. Conclure sur la nouvelle fonction de hachage imposée.
- (09) Conclure sur les résultats obtenus aux questions 05, 07 et 08.

La commande `mkpasswd` permet de hacher des mots de passe avec un salage.

- (10) Après avoir étudié le manuel de la commande `mkpasswd` (installer le paquet `whois` si besoin) donner la ligne de commande permettant de générer le haché de votre mot de passe (ou celui de `etudiant`) en fonction du mot de passe réel et du sel utilisé. Tester cette commande. Conclure.

3 ACTIVITÉ 3 : TUBE ANONYME, PIPE " | "

En informatique, un tube anonyme ou *pipe* désigne un flux de données exécuté entre deux processus. Cela signifie que le résultat de sortie d'une première commande peut servir d'entrée à une seconde. Cela permet, entre autres, de diviser des problèmes complexes en sous-problèmes plus petits.

Syntaxe d'un *pipe* : `COMMANDE_1 | COMMANDE_2`

- (11) En utilisant les commandes `cat` et `grep` et la syntaxe d'un *pipe*, réaliser une ligne de commande ayant le même effet que la question 07.

Il existe de nombreuses commandes de filtrage sous Linux, les plus connues sont : `grep`, `cut`, `sort`, `more`, `wc`.

- (12) Expliquer en détail cette commande : `sudo cat /etc/shadow | sort -n | cut -d : -f 1-2`. Pour bien comprendre le fonctionnement de cette commande, essayer tout d'abord de visualiser le fichier `shadow`, de comprendre ensuite les commandes `sort` et `cut` en consultant l'aide, puis d'ajouter le premier *pipe* et enfin le second.

4 ACTIVITÉ 4 : TUBE NOMMÉ, REDIRECTION ">" ET "<"

La redirection permet de modifier les flots d'entrée, de sortie ou d'erreurs.

- (13) Taper la série de commandes suivante, observer et expliquer les résultats obtenus :

```
cd ~/Documents/Info
tree
tree > redirection.txt
cat redirection.txt
tree /etc > redirection.txt
cat redirection.txt
tree >> redirection.txt
cat redirection.txt
```

- (14) Taper la série de commandes suivante, observer et expliquer les résultats obtenus :

```
echo tree > redirection.txt
cat redirection.txt
bash < redirection.txt
```

5 ACTIVITÉ 5 : RECHERCHER OU TESTER UN MOT DE PASSE AVEC JOHN

John the Ripper est un puissant logiciel open source de récupération de mots de passe qui utilise des techniques telles que la force brute et le dictionnaire pour retrouver des mots de passe à partir de hachages de mots de passe. Il est utilisé légalement pour tester la sécurité des mots de passe dans des environnements tels que les tests de pénétration et la récupération de mots de passe oubliés.



5.1 CRÉATION D'UN UTILISATEUR DE TEST

- (15) En utilisant les commandes `adduser` et `passwd`, créer un utilisateur nommé `toto` ayant comme mot de passe `123456789`. Vérifier la présence des lignes associées à l'utilisateur `toto` dans les 2 fichiers systèmes : `passwd` et `shadow`.
- (16) En utilisant les *pipes* et les redirections, donner une ligne de commande permettant de créer un fichier `hash.txt` contenant le nom utilisateur et le haché du mot de passe de `toto`.



5.2 RECHERCHE DU MOT DE PASSE PAR DICTIONNAIRE

(17) Installer `john` sur votre machine avec `apt`. Récupérer le dictionnaire de mots de passe `password.txt` sur le site <https://github.com/kkrypt0nn/wordlists/>.

(18) Expliquer les commandes suivantes. Tester les et conclure.

```
john hash.txt --format=crypt --wordlist=password.txt
```

```
john --show hash.txt
```

(19) Supprimer le compte `toto` avec la commande `userdel -r toto`.

Vous pouvez tester le haché de votre mot de passe ou celui de `etudiant` avec le dictionnaire `rockyou.txt` ou utiliser une technique par force brute (attention, cela prend beaucoup de temps...)